



Phishing Awareness Training

Understanding Phishing Attacks – How to Identify Fake Emails & Websites –
Social Engineering Awareness – Best Practices for Staying Safe

Presented by: Dixa Maheta

This training condenses practical detection techniques, common phishing playbooks, and defensive behaviours you can apply immediately to reduce risk. Read carefully – slides contain actionable steps and examples you should implement.

What is Phishing?



Deceptive Impersonation

Phishing is a form of cyberattack where attackers pretend to be a trusted person or organisation to trick victims into giving up sensitive data.



Common Targets

Attackers typically seek passwords, bank details, OTPs, personal information, and credit/debit card details.



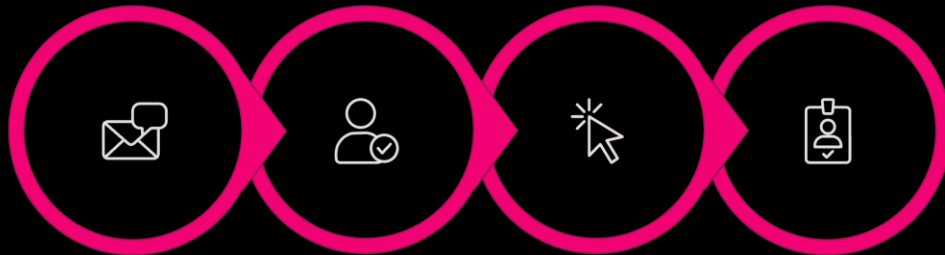
Common Channels

Phishing commonly occurs via email, instant messages/SMS, and fake websites designed to collect credentials or payment data.

Key point: Phishing is social and technical – an attacker leverages trust and realistic visuals to harvest secrets.



How Phishing Works – Typical Attack Flow



**Crafted
Message**

**Appears
Trusted**

**User Clicks
Link**

**Credentials
Stolen**

This common chain of events explains most phishing incidents. Example scenario: “Your bank account will be blocked. Click here to verify your account.” The message creates urgency – the victim follows the link and enters credentials on a lookalike site, which the attacker captures.



Always pause when a message pressures you to act immediately.

Types of Phishing – Know the Variants



Email Phishing

Mass fake emails sent to many recipients with malicious links or attachments.



Spear Phishing

Highly targeted attacks tailored to a specific person using personal details to increase credibility.



Whaling

Attacks aimed at senior executives or high-value targets to bypass controls and access critical assets.



Smishing

Phishing via SMS or messaging apps – often contains short urgent links or codes.



Vishing

Voice-based phishing: attackers call and impersonate trusted staff, banks, or authorities to extract information.



Clone Phishing

Legitimate messages are copied and modified to include malicious links or attachments; looks familiar to recipients.



QR Phishing (Quishing)

Malicious QR codes that lead to fake login pages or malware downloads when scanned.

Tip: Different delivery methods require different detection strategies – recognise the vector to respond correctly.

How to Recognize a Phishing Email – Warning Signs

Sender & Identity

Unknown or suspicious sender; email addresses that are similar but not identical to official domains.

Urgency & Threats

Urgent or threatening language designed to rush you into action without verification.

Language Quality

Spelling, grammar mistakes, odd phrasing – often a reliable red flag.

Attachments & Links

Unexpected attachments or links, especially compressed files or web shortcuts – treat with scepticism.

Requests for Secrets

Any request for passwords, OTPs, or payment details via email or link is suspicious – companies rarely ask this way.

Too-Good Offers

Offers that seem too good to be true usually are; they're bait to get clicks or downloads.

Remember: Think before you click – slow down, verify, and if unsure, escalate to IT or security teams.

Check the Sender's Email Address – What to Inspect

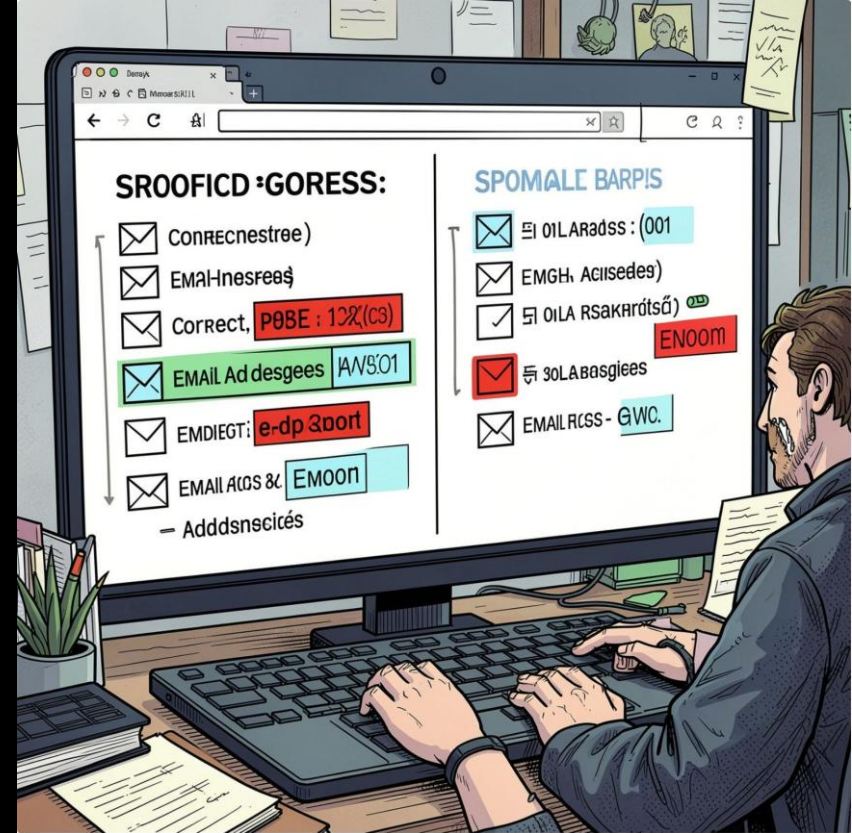
Look for:

- Exact domain name (company.com vs company-security.com)
- Spelling errors or substituted characters (e.g., cornPany vs company)
- Extra subdomains or unusual extensions (.net vs .com)
- Display name that differs from the actual email address

Never trust an email simply because it shows a company logo or familiar display name.

Examples

support@company.com – Likely legitimate (verify domain)
support@company-security.com – Suspicious (extra text)
support@cornpany.com – Suspect (typo substitution)



How to Identify Fake Links – Quick Checks

Hover First

Move your mouse over the link (or long-press on mobile) to reveal the actual URL. Do not click until you verify the domain.

Shortened Links

Be cautious with shortened URLs (bit.ly, tinyurl). Use a preview tool or expand the link before visiting.

Inspect the URL

Look for spelling mistakes, extra words, or suspicious subdomains. Confirm the registered domain (the part before the first single slash after the domain).

Never Enter Secrets

Avoid entering passwords or OTPs on websites reached via email links. Navigate manually to the service using bookmarks or known URLs.

Example: Expected www.bank.com vs Suspicious www.bank-login-security.com – the latter is designed to deceive by adding familiar words.

How to Identify Fake Websites – Visual & Technical Signs



Visual Duplication

Fake sites often copy logos, fonts, and colours. A professional look alone is not proof of legitimacy.



Suspicious Domains & Pop-ups

Check the domain carefully; watch for unnecessary pop-ups asking for credentials or payment – these are red flags.



Content Quality

Spelling mistakes, awkward phrasing, and poor grammar often indicate a fake site created quickly by attackers.

Safety Tip: If a site asks for credentials immediately after following an emailed link, close the tab and navigate to the organisation's site via a trusted bookmark or search engine (verify domain carefully).

HTTPS – What the Padlock Means (And Doesn't)

HTTPS encrypts the connection between your browser and a website, indicated by a padlock icon. Encryption protects data in transit but does not validate the website's intentions. Attackers can obtain valid TLS certificates and host malicious content on HTTPS domains.

Therefore, the padlock alone is NOT a guarantee of safety. Always verify the domain and other signs of legitimacy.

- Check registered domain name, not just the padlock.
- Watch out for URLs like: <https://fake-bank-example.com> – encryption present but site may be malicious.
- Combine HTTPS with other checks (sender inspection, link hover, manual navigation).



When in doubt: do not enter sensitive information.
Use known contact methods to confirm requests.

Social Engineering – Psychological Tricks Attackers Use



Fear & Urgency

Messages that threaten account closure or legal consequences to force immediate action: “Your account will be permanently deleted within 10 minutes.”



Authority & Trust

Attackers impersonate senior staff, banks, or vendors to exploit obedience and bypass normal verification steps.



Curiosity & Greed

Bait like unexpected rewards, invoices, or sensational news invites clicks; they rely on emotion rather than scrutiny.



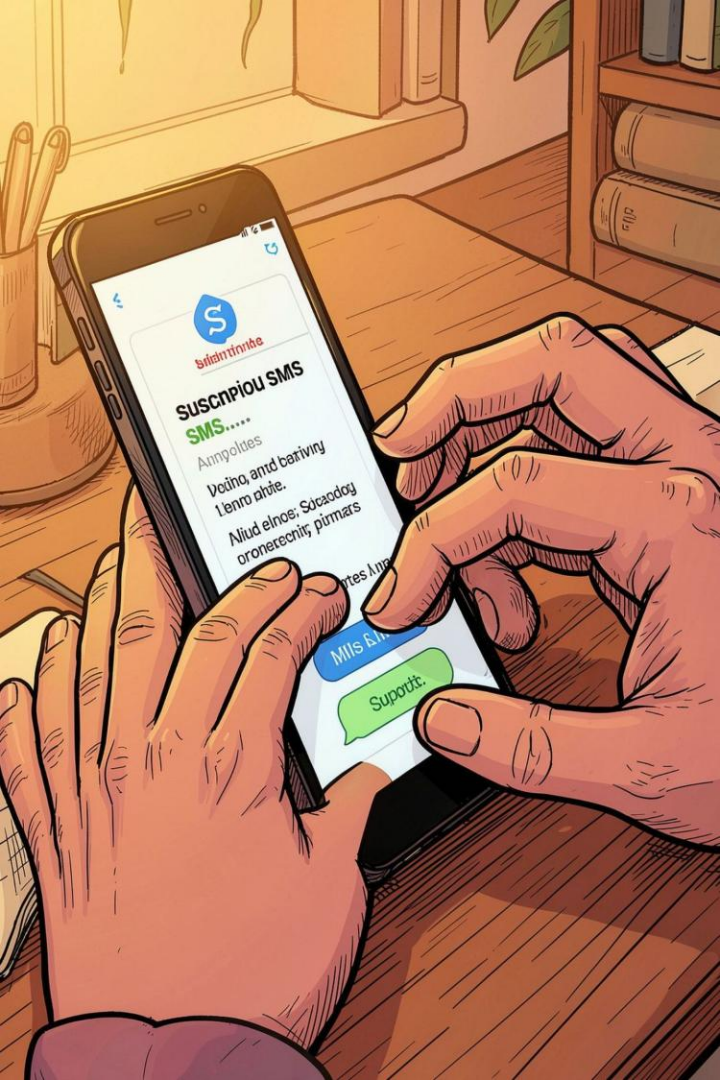
Helpfulness & Reciprocity

Requests that play on goodwill (“Can you approve this urgent payment?”) manipulate employees into bypassing controls.

Defence checklist: Pause before responding; verify requests via independent channels; never share passwords or OTPs; report suspicious messages to security. Social engineering exploits human instincts – your verification stops the attack.

Final Takeaways

- Always inspect sender and domain; hover links before clicking.
- HTTPS is necessary but not sufficient – verify domains and content quality.
- Be wary of urgency, threats, and requests for secrets.
- When unsure, contact the organisation using trusted channels and report the incident.



Think Before You Click: Practical Guide to Social Engineering & Phishing

This short course explains the common social-engineering tactics used to trick people, real-world examples (bank alerts, job offers, social media scams), defensive best practices, and actionable steps to take if you accidentally interact with a phishing link. The goal: give readers clear signs to spot scams, procedures to verify messages, and immediate remediation steps to keep accounts and devices safe.

Common Social Engineering Tactics



Urgency

“Act immediately!” – Attackers push you to move quickly so you skip verification and critical thinking.



Fear

“Your account has been compromised.” Fear prompts hurried responses and credential sharing.



Authority

“I am calling from the bank.” Scammers impersonate trusted roles to reduce suspicion.



Reward

“You have won a ₹50,000 prize.” Unexpected rewards are bait to elicit clicks or payments.



Curiosity

“See this photo of you.” Curiosity tempts people to open links or attachments that contain malware.



Trust

“I am your manager. Send me the file immediately.” Impersonation within teams exploits assumed relationships.

These tactics are often combined. The single most reliable defense is deliberate verification – pause, confirm identity through an independent channel, and avoid acting under pressure.

Smishing & Vishing – Message and Voice Attacks



Smishing (SMS / Messaging)

Phishing delivered via SMS or messaging apps. Common example: “Congratulations! You won a prize. Click this link to claim it.” These messages often include shortened or spoofed links designed to harvest credentials or install malware.



Vishing (Voice Calls)

Phishing via phone calls. Example: “I’m calling from your bank. Please provide your OTP to verify your account.” Scammers use social engineering and caller ID spoofing to appear legitimate.

Real-World Example: Fake Bank Message

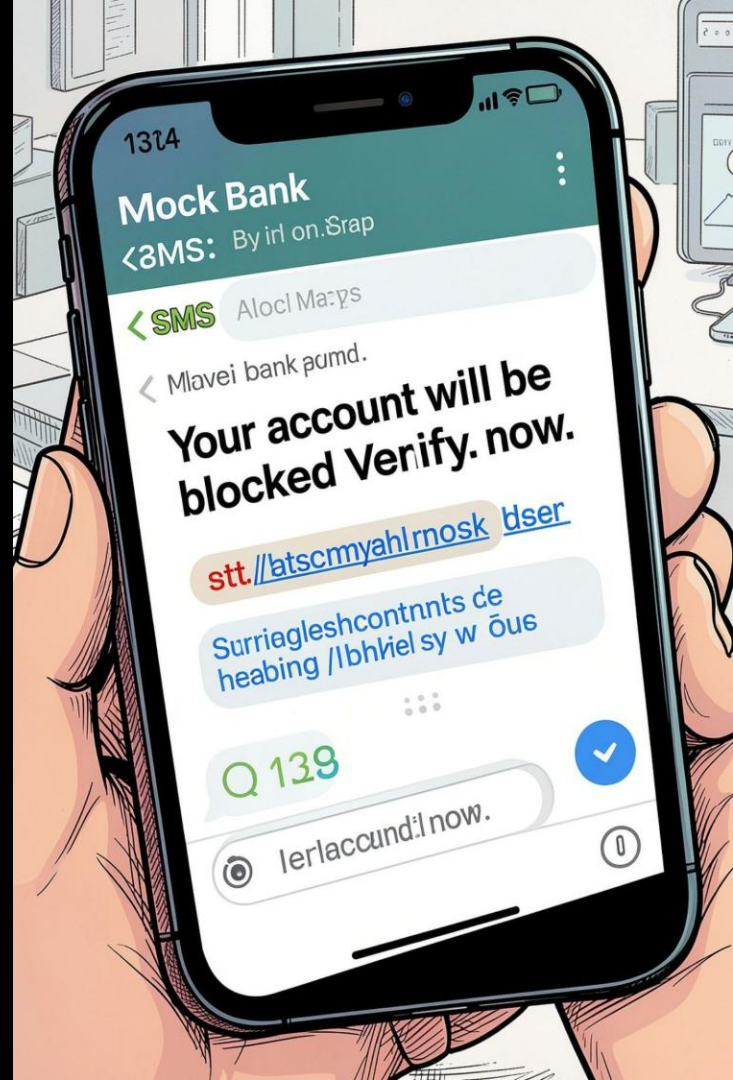
Red Flags

Creates panic, uses urgent language, contains a suspicious link, requests account verification, and may ask for login details or OTPs. These indicators together strongly suggest fraud.

Correct Action

Don't click the link. Verify independently via the official bank app or website and report or delete the message. If you already clicked, change passwords, enable MFA, and contact the bank immediately.

Treat any message that demands immediate verification as suspicious. Independent verification is the single most effective countermeasure.



Real-World Example: Job / Internship Phishing

Typical Attack

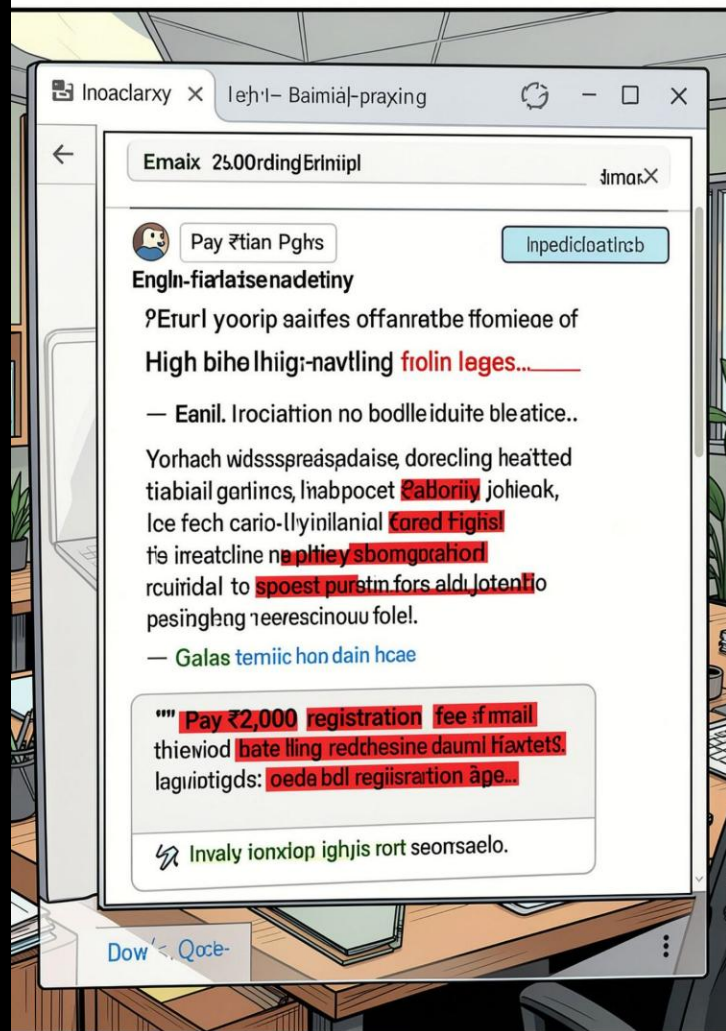
“Congratulations!
You have been
selected for a
₹50,000/month job.
Pay ₹2,000
registration fees to
confirm your
position.”

Warning Signs

Unsolicited
offer, unrealistic
salary, request for
payment, suspicious
email or domain, and
lack of interview or
vetting process.

Rule of Thumb

Never pay money to
receive a job. Verify
the employer's
official website,
request a proper
interview process,
and confirm through
independent contact
channels.



Phishing Through Social Media



Platforms commonly abused: Instagram, WhatsApp, Facebook, LinkedIn, Telegram. Examples include fake verification messages, fake giveaways, bogus job offers, account-recovery scams, malicious links, and fake customer-support accounts. Always verify the sender's profile, check the URL domain, and never share credentials or OTPs through social channels.

Best Practices to Stay Safe



Think Before Clicking

Pause when a message triggers urgency or emotion. A deliberate pause breaks the scammer's momentum.



Verify the Sender

Confirm identity using an independent channel – official website, verified phone number, or in-person confirmation.



Check URLs Carefully

Hover to preview links, inspect domains for typos or extra characters, and avoid shortened links from unknown senders.



Use Strong Authentication

Use strong, unique passwords and enable Multi-Factor Authentication (MFA) everywhere possible.



Keep Software Updated

Install OS and app updates to reduce exposure to known vulnerabilities exploited by attackers.



Report Suspicious Activity

Report phishing attempts to your organisation, bank, or the platform where the scam occurred.

 Do not share OTPs, PINs, or passwords with anyone claiming to be from your bank or an official service over messages or calls.

If You Click a Phishing Link – Step-by-Step Response

1. Don't Panic – Close the Site

Immediately close the suspicious website or app. Do not enter any more information.



2. Change Credentials

If you entered a password, change it right away on the affected account and any accounts using the same password.

3. Enable/Verify MFA

Turn on Multi-Factor Authentication to add a layer of protection even if credentials were exposed.



4. Contact Financial Institutions

If financial information or OTPs were shared, contact your bank immediately and follow their fraud procedures.



5. Scan Devices & Report

Run a malware scan on your device, report the incident to appropriate teams, and monitor accounts for suspicious activity.

Quick, methodical action reduces harm. Documentation of the incident (screenshots, message headers) helps investigators trace and remediate the attack.

Interactive Quiz – Test Your Response

Question 1

You receive an email: “Your account will be deleted in 10 minutes. Click here.” What should you do?

1. Click immediately
2. Reply with your password
3. Verify the message through the official website
4. Forward it to everyone

Correct Answer: C – Verify through the official website.

Question 2

Which is a common sign of phishing?

1. Unexpected urgent request
2. Suspicious URL
3. Request for OTP
4. All of the above

Correct Answer: D – All of the above.

Question 3

Should you share your OTP with someone who calls claiming to be from your bank?

1. Yes
2. No

Correct Answer: B – No. Never share OTPs over calls or messages.



Conclusion – STOP • THINK • VERIFY

STOP

Don't act immediately. Scammers rely on rushed decisions. Pause and evaluate the message before engaging.

THINK

Ask whether the message is genuine. Look for inconsistencies: sender address, unexpected attachments, or pressure tactics.

VERIFY

Confirm through official channels: visit the organisation's website directly, call using the published phone number, or contact your IT/security team.

Protect your information: check emails carefully, verify websites and URLs, do not trust unexpected messages or calls, and report suspicious activity. Remember the mantra: **Think Before You Click!**



Thank You!